Security Architecture Assessment Report

Subject: Network Segmentation, System Hardening, and Compliance Monitoring Review
Assessor: Mitchelle Anduru
Role: Junior Cybersecurity Engineer
Assessment Date: 07 March 2026

1. Executive Summary

This assessment evaluated the security architecture of a segmented enterprise environment consisting of a web server, database server, internal application server, compliance server, and desktop testing workstation. The review focused on the effectiveness of network segmentation, firewall enforcement, server hardening, compliance monitoring, and alignment with recognized security practices, particularly PCI DSS-oriented controls for protecting sensitive systems and reducing attack surface.

Overall, the architecture demonstrates a sound security design principle: systems were separated into distinct trust zones, sensitive assets were restricted from direct external exposure, and a dedicated compliance server was positioned to support monitoring and vulnerability management. This approach materially reduces lateral movement risk and helps narrow exposure of high-value systems such as the database server. However, the review also identified architectural and operational considerations that require attention, especially around the concentration of trust in the compliance server, the need for stronger web and database hardening, the importance of logging maturity, and the need to balance segmentation with operational efficiency.

From a real-world perspective, this environment reflects a strong baseline for a PCI-sensitive network, but its security effectiveness ultimately depends on disciplined firewall enforcement, secure service configuration, centralized monitoring, and ongoing validation through both automated and manual assessment methods.

2. Assessment Scope and Objectives

The purpose of this assessment was to review the architecture and control design of the environment in the following areas:

- network segmentation strategy
- firewall rule design and enforcement
- web server hardening
- database server hardening
- use of a compliance server as a monitoring and transfer intermediary
- vulnerability scanning and compliance validation
- security effectiveness, operational challenges, and future improvements

The assessment was conducted as a design and control review based on the documented lab environment, intended security requirements, and expected compliance posture.

3. Environment Overview

The reviewed environment was segmented into the following systems and zones:

- **Web Server:** 192.168.10.10
- **Database Server:** 192.168.20.10
- **Internal Application Server:** 192.168.30.10
- **Compliance Server:** 192.168.40.10
- **Desktop VM:** 192.168.40.17

The intended design enforced restricted communication paths between these systems, with particular focus on preventing direct access from less trusted zones into the database and internal server segments while still allowing required monitoring and operational traffic to the compliance server.

4. Network Segmentation Assessment

4.1 Purpose of Segmentation

Network segmentation is a foundational security control because it limits unnecessary communication between systems, reduces attack surface, and restricts the ability of an attacker to move laterally after initial compromise. In environments that store, process, or transmit payment-related data, segmentation is especially valuable because it helps isolate the cardholder data environment from less trusted systems and reduces the number of systems exposed to high-risk pathways.

In this architecture, segmentation was designed to ensure that:

- the web server could support business-facing connectivity without unrestricted east-west access
- the database server remained protected from direct external access
- the internal server stayed isolated while offline for forensic or controlled reintegration purposes
- the compliance server acted as a centralized point for monitoring, scanning, and authorized security-related communications

This design reflects accepted security best practices, including least functionality, trust-zone separation, and reduced connectivity into sensitive systems. It also aligns with the broader intent of PCI DSS controls that emphasize limiting access paths into environments containing sensitive payment data.

4.2 Security Value of the Segmentation Model

The segmentation model provides several clear benefits:

- it reduces the likelihood that compromise of the public-facing web server would immediately expose the database layer
- it prevents unnecessary direct communication between critical systems
- it creates more defensible security boundaries for monitoring and incident response

- it preserves secure reintegration options for the internal server after forensic review or operational restoration

In practice, segmentation is one of the most effective controls for limiting blast radius. Even where a frontline system is compromised, properly enforced network boundaries can prevent the event from becoming a broader enterprise breach.

5. Firewall Configuration Review

5.1 Intended Firewall Enforcement

The firewall rule set was designed to enforce strict control over inter-segment traffic. The intended policy approach included:

- allowing the web server outbound internet access where operationally required
- denying direct communication from the web server to the database server
- denying direct communication from the web server to the internal application server
- allowing approved communications from servers to the compliance server for monitoring, scanning, and controlled relay functions
- denying direct internet access for the database server
- preserving isolation of the internal server while offline
- restricting management access to trusted administrative sources only
- applying a default-deny model for all non-authorized traffic

5.2 Security Impact of the Firewall Design

This rule structure is appropriate for a PCI-sensitive environment because it enforces explicit trust boundaries and prevents uncontrolled internal movement between tiers. The most important protection is the separation of the web and database layers. In real-world attacks, compromise of a public-facing web service is often the first step, and the next attacker objective is commonly to pivot into the database or internal application environment. Denying these paths by default materially improves resilience.

The rule choices also support operational functionality by allowing only those flows required for business service delivery, monitoring, and controlled administration. This is consistent with least privilege at the network layer.

5.3 Architectural Risk Considerations

Although the firewall logic is sound, its effectiveness depends on several operational details:

- correct rule order and precedence
- route persistence across reboot and system changes
- accurate documentation of permitted flows
- periodic validation that new services or hosts have not bypassed the intended policy model

Without ongoing review, even a well-designed rule base can become ineffective over time due to configuration drift or operational exceptions.

6. Web Server Hardening Assessment

6.1 Observed Risk Areas

The web server was correctly identified as the highest-risk asset because it is customer-facing and exposed to the broadest threat surface. Key weaknesses noted in the assessment included:

- HTTP-only exposure
- weak SSL/TLS configuration
- unnecessary open ports
- disabled or insufficient logging
- possible SQL injection exposure
- possible cross-site scripting exposure

6.2 Hardening Measures

The recommended hardening actions were appropriate and reflect real-world expectations for a web-facing service:

- redirecting HTTP traffic to HTTPS
- enforcing strong TLS versions and secure cipher configuration
- disabling non-essential ports and services
- enabling access, authentication, administrative, and application error logging
- reviewing input handling to reduce SQL injection risk
- reviewing output handling and sanitization to reduce XSS risk

These measures are important because web-layer weaknesses are among the most common entry points for compromise. Strong transport security protects data in transit, while input validation, parameterized queries, and output encoding help reduce exposure to application-layer attacks that infrastructure controls alone cannot prevent.

6.3 Automated vs Manual Detection

The assessment correctly recognized that tools such as Nessus and Wazuh can identify many infrastructure and configuration weaknesses, including weak TLS support, exposed services, vulnerable packages, and suspicious events. However, application-layer issues such as SQL injection and XSS are not always fully identified through general infrastructure scanning and often require targeted manual testing and secure code review.

This is an important real-world point: automated scanners provide scale and consistency, but they do not replace analyst validation, especially for business-logic and application-layer flaws.

7. Database Server Hardening Assessment

7.1 Risk Profile

The database server represents the most sensitive system in the environment because it stores PCI-related or otherwise sensitive data. As such, it requires stricter controls than general-purpose internal systems. The assessment appropriately highlighted the need for:

- stronger access controls
- restricted database access to approved systems only
- minimized remote access exposure
- protection of stored sensitive data through encryption
- enabled auditing and logging
- least-privilege account configuration

7.2 Security Value of the Recommended Controls

These controls directly improve both security and compliance posture. Restricting access reduces the risk of unauthorized viewing, modification, or extraction of sensitive records. Encryption reduces the impact of storage compromise. Logging and auditing improve accountability and allow suspicious activity to be detected and investigated. Least-privilege permissions reduce the damage that can occur if an application account or administrator credential is abused.

In real-world enterprise environments, database security is often the difference between an attempted intrusion and a reportable breach. A compromised web server is serious; a compromised database containing regulated data is far more severe.

8. Compliance Server Architecture Review

8.1 Security Benefits

Using a dedicated compliance server as an intermediary for monitoring, vulnerability scanning, and controlled transfer operations can be a valid architectural choice. In this environment, it provides:

- centralized monitoring visibility
- a controlled communications hub for Wazuh and Nessus-related activities
- a buffer that prevents direct communication between the web and database segments
- stronger separation of duties between production systems and compliance tooling

From a segmentation perspective, this is defensible because it narrows direct trust paths and centralizes oversight.

8.2 Architectural Weaknesses

At the same time, the compliance server introduces concentrated risk. Because it sits in a privileged position across multiple segments, it becomes a high-value target. If compromised, it could expose monitoring data, alter scan visibility, influence transferred files, or serve as a stepping stone across trust boundaries. It may also become a bottleneck or single point of operational failure.

This means the compliance server must itself be treated as a highly sensitive asset and hardened accordingly.

8.3 Improvement Opportunities

Several improvements would strengthen this design without undermining segmentation goals:

- separating monitoring functions from backup relay or transfer functions
- encrypting backups before transfer, not only during transfer
- enforcing strict SSH key protection and host verification
- ensuring transfer jobs run with least privilege
- logging all transfer activity centrally
- considering dedicated secure transfer infrastructure or staged repositories instead of a shared intermediary model

These improvements would reduce trust concentration while preserving operational control.

9. Vulnerability Management and Compliance Review

9.1 Role of Nessus and Wazuh

The assessment appropriately positioned Nessus and Wazuh as complementary tools. Nessus provides value as an active vulnerability scanner that can identify weak services, missing patches, insecure protocols, and exposed network weaknesses. Wazuh supports continuous visibility through agent-based telemetry, vulnerability detection, event collection, and centralized log analysis.

Used together, these tools improve both point-in-time assessment and ongoing monitoring.

9.2 Automated vs Manual Audits

Automated compliance and vulnerability tools offer important advantages:

- scale
- repeatability
- speed
- broad coverage of known configuration and exposure issues

However, they also have limitations:

- reduced ability to interpret business context
- incomplete detection of application logic flaws
- dependence on configuration quality and scan scope
- potential false positives or incomplete findings

Manual assessment, by contrast, is more effective where analyst judgment is needed, particularly for:

- validating business-required flows
- testing web application behaviour
- assessing segmentation logic in context

- confirming that remediation actions actually reduced risk

The strongest approach is a hybrid model that combines automated scanning with human review. This improves detection quality, reduces blind spots, and better supports sustainable compliance.

10. Implementation Challenges

The assessment identified a realistic operational challenge in segmented environments: balancing security and functionality. Overly restrictive controls can break required monitoring, backup, or management flows; overly permissive ones weaken the value of segmentation.

Another practical issue was route persistence. Temporary routing changes may work during testing but fail after reboot if not persisted correctly in system configuration. In production environments, this kind of issue can create false assumptions about firewall failure when the real issue is routing inconsistency.

This observation is strong because it reflects a real-world truth: security architecture does not fail only because of bad policy. It also fails because of incomplete implementation and operational drift.

11. Overall Security Effectiveness

The security model was effective in principle because it enforced tier isolation, protected sensitive systems from broad exposure, and created defined trust boundaries for monitoring and administration. The firewall rules supported access control by allowing only required communication paths, and the broader architecture aligned with accepted defensive design principles for environments handling sensitive data.

That said, the long-term effectiveness of this environment depends on disciplined operations. Segmentation is only as strong as the firewall enforcement behind it, and hardening is only as effective as the monitoring and validation processes that sustain it over time.

12. Strategic Recommendations

The following actions are recommended to strengthen the environment further:

Immediate priorities

- validate all segmentation rules against documented business requirements
- harden the compliance server to the same standard as other high-value assets
- enforce HTTPS and strong TLS on the web server
- tighten database access to approved hosts and least-privilege accounts
- centralize logging across web, database, system, authentication, and transfer events

Near-term improvements

- encrypt backups before transfer
- strengthen administrative access controls and trusted-source restrictions
- regularly review firewall rule order, route persistence, and default-deny posture
- run periodic Nessus scans and correlate results with Wazuh telemetry

Longer-term maturity actions

- add file integrity monitoring on critical systems
- separate monitoring and transfer roles across different infrastructure where feasible
- perform periodic manual application security testing in addition to automated scanning
- establish recurring architecture review and rule recertification processes

13. Conclusion

This assessment found that the reviewed environment demonstrates a solid security architecture foundation built around segmentation, least connectivity, controlled monitoring, and protection of high-value systems. The separation of the web, database, internal, and compliance zones reflects a strong defensive design approach and aligns well with PCI-sensitive security principles.

The main areas requiring further maturity are not the overall design intent, but the operational details that determine whether the design remains secure in practice: hardening of exposed systems, strict control of the compliance server, centralized logging, validation of routing and firewall persistence, and continued use of both automated and manual security testing. With these improvements, the environment would more closely reflect a professionally managed, compliance-conscious enterprise security architecture.